Chatbot Gateway 인수인계서

2026-10-23

이 문서는 운영·개발 담당자를 위한 역할, 설정, 실행 및 검증 안내임. API 계약은 아래 문서를 따름.

문서	내용
G/W 설계	세션·로그인·클릭·자동완성
B/E 연동	경로·세 헤더·ag-ui 요청 및 SSE
통합인증	X-Mfa-Result·PFC 검증·interrupt 재개·오류

구성과 책임

구성	책임
G/W	Java 21, Spring Boot, MVC/Tomcat. 세션·채널 접근 확인, PFC 인증 검증, HTTP/SSE 중계
Agent B/E	대화 소유권·이력, interrupt·업무 상태, 실제 실행·중복 방지
agent-session-service	세션 생성·조회·활동 연장·교체 및 원자성
PFC/MCI	로그인·통합인증, 티켓 소비·기한·재시도 제한, 홈페이지 쿠키 연계
Document DB	staging 채널의 고객 허용 목록
search-autocomplete-service	자동완성 검색

주요 흐름

상황	처리
첫 진입	start(POST /api/auth/session) → MEMBER이면 목록·최근 대화 이력 조회, GUEST이면 새 대화
로그인 복귀	_O를 포함해 start 호출. 검증 성공은 회원, 인증 실패·PFC 장애는 게스트 세션 생성
start 세션	_O 없이 유효 세션이면 재사용, 채널 쿠키가 없으면 게스트 생성. 기존 세션 만료·폐기·잘못된 SID는401
만료 복구	G/W가 401과 해당 채널의 만료 쿠키 삭제를 반환. FE가 start 후 MEMBER이면 목록·이력 조회, GUEST이면 새 대화
새 대화	FE가 새 threadId를 생성해 POST /api/chat에 전달. B/E가 새 대화 생성
대화	POST /api/chat → B/E의 동일 경로. RunAgentInput·ag-ui SSE 중계
통합인증	FE SDK → X-Mfa-Result + 단일 resume → G/W PFC 검증 → 성공 시 interruptId 전달
클릭	POST /api/click. 세션 연장·AUDIT JSON 로그
자동완성	POST /api/chat/auto → 검색 서비스

G/W→B/E 사용자 정의 헤더는 다음 세 개임. G/W가 검증한 값으로 구성함.

헤더	전달 조건
X-Authenticated-User-Id	모든 요청
X-Authenticated-Channel-Id	모든 요청
X-Verified-Request-Id	통합인증 성공 시 단일 interruptId

통합인증 실패는 B/E 호출·SSE 시작 전에 JSON 오류로 반환함. 입력400 INVALID_ARGUMENT, 세션401 UNAUTHENTICATED, 인증403 MFA_INVALID, 연동503 UNAVAILABLE, 기타500 INTERNAL_ERROR임. B/E는 인증 필요 업무의 헤더와 대기 interrupt를 대조하고 중복 실행을 막음. PFC 소비 후 전달 실패 시 재인증이 필요할 수 있음.

_O를 포함한 start는 로그인 인증 결과로 새 세션을 생성함. _O 검증 실패·PFC 오류·timeout이면 agent-session-service를 통해 게스트를 생성함. _O 없이 채널 세션을 재사용할 때 만료됐으면401 UNAUTHENTICATED이며 게스트로 대체하지 않음. 세션 생성·조회·갱신 실패는503 UNAVAILABLE임. 세션 준비 성공은200이며 userType은 문자열 MEMBER/GUEST임. 회원 복구에는 새로운 _O 인증이 필요함. 게스트가 허용되지 않는 채널의 접근은403으로 거절함. 업무 통합인증에는 게스트 전환을 적용하지 않음.

코드 탐색

기준 경로: src/main/java/com/example/chatgateway/.

위치	확인 영역
controller/ChatSessionController	start 세션 생성·재사용
service/SessionAuthentication	세션·채널·start의 _O 인증
controller/ChatController, service/ChatService	대화·위자드·이력 요청과 중계
service/ChatAuthenticationService	중계 전 인증 처리
client/agent/AgentBackendClient, BackendHeaders	목적지·경로·헤더 구성
service/SseRelayService, config/UpstreamClients	SSE 수명·연결 풀·timeout
gateway/MfaResultParser, service/MfaService, client/pfc/PfcClient	통합인증 입력·PFC 호출
client/session/HttpSessionServiceClient, session/AuthorityStore	외부 세션 서비스 계약
service/ChannelAccessService	staging 허용 목록·캐시
service/ClickService, client/search/AutocompleteClient	클릭 로그·자동완성

세션·SSE 운영 규칙

로그인 세션은 사용자·채널·인증 상태·기한을 보관함. threadId는 FE가 요청에 전달하고 B/E가 소유권·이력·만료를 관리함.

모든 FE 세션 요청에 query channelId를 필수로 전달함. 쿠키 이름의 channel-prefix는 전체 채널 UUID의 첫 구간임. 채널별 세션은 독립적이며 허용 목록의 접두사 중복은 시작 시 오류임. B/E에는 channelId query 대신 검증된 채널 헤더를 전달함.

항목	규칙
세션 쿠키	__Host-sh-session_〈channel-prefix〉, HttpOnly·Secure·SameSite=Lax·Path=/
세션 수명	인정 활동 후 5분. GET·SSE 수신·자동완성은 연장 제외
공통 응답	유효 세션이면 X-Chat-User-Type(MEMBER/GUEST)·X-Chat-Auth-Expires-At·X-Server-Time. 시각은 UTC epoch milliseconds

항목	규칙
SSE	data-only ag-ui 원문 중계, B/E EOF에서 종료
읽기 제한	B/E 데이터 수신 간격 기본30초
동시 중계	기본100. 초과 시503. 운영 용량은 부하 검증으로 결정
업무 중복 처리	B/E가 interrupt·업무 상태를 기준으로 처리
오류	B/E HTTP 상태·본문 중계. 스트림 시작 후 오류는 HTTP 상태 변경 불가
중계 자원	완료·브라우저 단절·예외에서 연결 및 동시 요청 슬롯 반환

공통 응답 헤더는 G/W→FE의 JSON·SSE·B/E 오류 응답에 적용함. 유효 세션을 확인할 수 없으면 X-Server-Time만 반환함. GET·자동완성은 현재 만료시각만 반환하고 SSE 헤더는 스트림 시작 시 한 번 전달함.

환경 설정

설정	용도
chat.channels.allowed	허용 채널
chat.backend.base-url	production B/E 주소
chat.staging.channels	staging 채널 UUID → B/E 주소
chat.staging.mongo-uri / database	허용 목록 DB 연결
chat.staging.cache-ttl / cache-size	허용 결과 캐시. 기본1분 / 10,000건
SESSION_SERVICE_CREDENTIAL	G/W→세션 서비스 인증값
EUREKA_URL	세션·검색 서비스 탐색
AUTOCOMPLETE_BASE_URL	로컬 검색 서버 주소
logging.jsonfile.path	클릭 AUDIT 로그 경로

staging은 PFC 인증 회원 중 허용 고객만 접근함. DB 컬렉션 channel_customer_access는 channelId, customerId, enabled를 사용하며 channelId+customerId 고유 인덱스가 필요함. G/W 계정은 조회 권한을 사용함. 유효 캐시는 TTL까지 사용하고, 만료 후 DB 장애는503으로 처리함.

클릭 로그의 sessionId는 threadId, userId는 회원 PID이며 게스트는 null임. 일별 분리·14일 보관. 인증값과 민감정보는 기록하지 않음. 200은 로그 호출 성공이며 수집기의 영구 저장 보장은 아님.

실행·검증

Java 21 사용.

```
./gradlew bootRunOffline
./gradlew spotlessCheck check bootJar
```

offline 자원은 src/offline에 있고 배포 JAR에서 제외함. local/dev/prod와 offline은 혼용하지 않음. Swagger UI는 local·offline의 /docs/index.html에서 제공함.

점검	기준
테스트 보고서	build/reports/tests/test/index.html, build/reports/tests/offlineTest/index.html
세션	쿠키·_O 부재 또는 _O 거절·PFC 장애 시 게스트 생성, 기존 세션 만료401·해당 쿠키 삭제, 세션 서비스 장애503·채널 독립성
복구	start 결과 MEMBER이면 목록·이력 조회, GUEST이면 새 대화. 회원 복구 시 새로운 _O 인증

점검	기준
응답 헤더	JSON·GET·자동완성·SSE·B/E 오류의 세션 정보, 세션 미확인 시 서버 시각만 반환
B/E 요청	start 후 목록·메시지 이력·채팅 순서, 대화 소유권, 세 헤더
통합인증	입력·세션·PFC 성공/실패, 단일 interrupt ID, 실패 시 upstream 미호출
SSE	첫 이벤트·snapshot·interrupt·긴 응답·단절·timeout·자원 반환
접근 권한	staging 게스트 거절·회원 허용 목록·캐시 만료·DB 장애
운영 E2E	PFC 티켓·쿠키, 세션 서비스 원자 교체, 프록시 buffering, 로그 수집

배포 전 실제 PFC·B/E·세션 서비스 연동을 검증함.

PDF 재생성

```
python docs/tools/build-api-pdf.py --font /path/to/korean.ttf
```

필요 도구: ReportLab, 한국어 TTF, Mermaid CLI(mmdc), Chrome/Chromium. Markdown 원본에서 PDF와 시퀀스 다이어그램을 생성함.